Monthly Intelligence Dispatch

February 2019

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specialises in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, leaks and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- Payment data of thousands of online stores' customers in the US and the UK may have been compromised by a new JS Sniffer called GMO, Group-IB has established
- **McAfee** has linked Operation Sharpshooter, a malware campaign that hit at least **87** nuclear, defence, energy and financial companies around the world, to the North Korean group Lazarus.
- Symantec says Whitefly group was behind a major leak of patient data at **SingHealth**, Singapore's largest public health organization.
- Silence group was behind a theft at **IT Bank**, a Russian bank, in February 2019. The group used a new Trojan.
- On 23 February, Silence launched a phishing campaign under the name of the Bank of Korea
- The theft at Malta's **Bank of Valetta**, which had initially been attributed to Cobalt, was actually committed by a different group, who meticulously imitate well-known cybercriminals to throw researches off the track.
- **On 27 February**, **Cobalt** group sent phishing emails to European banks. Their malware was detected in **Romania** and the **UK**.
- Group-IB discovered new databases with a total of **69,189** Pakistani bank cards, which had been put up for sale on the Dark Web. Their total market value is estimated at almost $**3.5m**.
- The SpeakUp backdoor exploits different vulnerabilities in six different Linux distributions and can also infect Mac systems.
- The Russian police in conjunction with experts from Group-IB arrested a **botnet** administrator in Novokuznetsk, a Russian city in Kemerov Oblast. The botnets comprised several thousand infected computers within and outside Russia.

GMO

Group-IB observed a new JS Sniffer intended for interception of user data, such as bank card numbers, names, addresses, logins and passwords. The first resource Group-IB experts found the sniffer on belonged to the sportswear giant **FILA** (fila.co[.]uk). At least **5,600** FILA customers may have fallen victim to the payment data theft over the last four months. Later, Group-IB discovered other websites infected with the JS Sniffer (called GMO). The victims included **six** US online stores, with some **350,000** unique visitors per month overall. The affected stores were: http://jungleeny[.]com (designer home accessories), https://forshaw[.]com/ (anti-insect products), https://www.absolutenewyork[.]com/ (cosmetics), https://www.cajungrocer[.]com/ (groceries online), https://www.getrxd[.]com/ (exercise equipment), https://www.sharbor[.]com/ (video editing equipment). Group-IB transferred the information to relevant organisations in the UK and the US. By the time the news was released, FILA and some of the other affected resources had updated their websites and deleted the sniffer.

GMO is a family of JS Sniffers that target websites powered by **CMS Magento**. One of GMO's unique characteristics is that it can recognise when it is being analysed. The sniffer detects Firebug and Developer Tools being opened. The domain name that hosted the sniffers' code and the gate for stolen data was registered on **7 May 2018**. The date can be regarded as the start of the GMO JS Sniffer campaign. The sniffer is part of **15** sniffer families described in Group-IB's new report, which is to be published soon. Group-IB has discovered a total of **38** different JS sniffer families. Group-IB's Threat Intelligence customers will be the first to have access to their descriptions.

Major events: espionage, sabotage, leaks

APT40	APT40 group, linked to the Chinese government, has been actively targeting countries participating in the **Belt and Road initiative**, such as Cambodia, Belgium, Germany, Hong Kong, the Philippines, Malaysia, Norway, Saudi Arabia, Switzerland, the US and the UK. China has been implementing the ambitious programme since **2013**, with the aim to create a transport infrastructure to connect more than **60** countries in Asia, Europe and Africa. APT40 has been active since at least **2013** and has apparently been focusing on supporting the Chinese government's efforts to modernise the navy industry. The hackers have been targeting engineering, transport and defence industries, but experts note that the group has a special interest in naval technology. The cyberspies attack naval research centres and universities. Among APT40's victims are also organisations that are involved in geopolitical operations in Southeast Asia or disputes over the South China sea.
Lazarus	**McAfee** security researchers have linked Operation Sharpshooter, a malware campaign that hit at least **87** nuclear, defence, energy and financial companies around the world, to the North Korean group Lazarus. There were earlier suspicions based on the research of their tools, but it was the analysis of previously unknown command and control centres that helped identify new victims and attribute the attacks to the North Korean hacking group. Lazarus is one of the most dangerous and experienced APT groups, with the hackers specializing in cyberespionage and sabotage against companies and government agencies in the US and South Korea. They later started to attack banks and cryptocurrency exchanges.

Major events: espionage, sabotage, leaks

APT28	**Microsoft** claims that between September and December 2018, group APT28 (aka Fancy Bear, Pawn Storm, Sofacy Group) carried out several cyberattacks on democratic institutions in Europe. Experts believe that the cybercriminals attacked **104 accounts** belonging to the employees of governmental and non-profit organisations in Belgium, France, Germany, Poland, Romania and Serbia. Among the victims were the employees of the German Council on Foreign Relations, Aspen European Institutes and the German Marshall Fund. The hackers launch phishing attacks to steal employees' account data and distribute malware. APT28 has been active since at least 2007 and has targeted governments and defence organisations around the world. The hackers have been accused of a number of attacks targeting the 2016 US presidential election. In 2017-18, APT28 resumed their secret information-gathering operations in Europe and South America.
Whitefly	Symantec specialists linked the attack on **SingHealth**, Singapore's largest medical organization, to Whitefly group. SingHealth has a network of two hospitals, five national specialty centres, nine polyclinics, and Bright Vision public hospital. Due to a major leak in 2018, SingHealth had 3 years' worth of data stolen, which affected some **1.5m** patients. The compromised material included personal data and national registration identity card (NRIC) numbers. In addition, the hackers stole information about outpatient prescriptions of about 160,000 patients. Singapore's Prime Minister Lee Hsien Loong and other ministers were among those, whose data had been stolen. Symantec believes that Whitefly is behind the leak. The group has been engaging in cyberespionage in Singapore since 2017. After the incident, Singapore's privacy watchdog imposed a fine of $1m on SingHealth and its IT vendor.

APT33	**Microsoft** security experts have announced that over the last two years, about **200** companies have been attacked by APT groups linked to Iran. The hackers stole confidential data and deleted information from computer networks. **Microsoft** is estimating the damage at **hundreds** of millions of dollars. The cyberattacks have targeted energy companies, aviation, and heavy industry in Saudi Arabia, Germany, the UK and India. The most active among these groups has been Holmium, also known as APT33. The group has been around since about **2013**. Microsoft describes a large-scale phishing attack by Holmium that targeted about **2,200** people. In 2017, **FireEye** observed attacks by APT33 group, targeting aerospace and energy organisations in the US, Saudi Arabia and South Korea.
APT39	APT39, another Iran-linked group, has been carrying out a large-scale campaign using a wide range of publicly available tools. The cyberspies have launched operations in the Middle East, the US and South Korea. Most of their victims are in the telecommunications or travel industries. Other victims include high-tech companies and governments. The group has been active since at least November **2014** and has been linked to operations that were previously attributed to Chafer and OilRig due to their common tools and infrastructure.

Major events: targeted attacks on banks

Silence

Group-IB has researched an ATM malware that was used in attacks on **IT Bank** (Russia) in February 2019. The experts believe that the criminal group Silence was behind the attack. This time, however, they deployed a new Trojan instead of **Atmosphere**, a tool they had previously used. As we have reported earlier, Silence sent bulk emails to Russian banks in mid-January 2019. IT Bank was one of the recipients of the malicious emails. Media outlets later reported that there had been a successful theft of funds at IT Bank. On 25 February, the malicious file was uploaded on VirusTotal from Russia. Group-IB experts analysed it and concluded the following: users from IT Bank were among the recipients of the malicious emails in January 2019. Debug information of the IT-bank Trojan (bkittest) was discovered. The compilation date of the new Trojan was 10 February, two days before the theft. The new Trojan differs from Atmosphere, the Trojan that Silence previously used.

Group-IB also found Silence's new server, which was used on **23 February** to send emails under the name of the **Bank of Korea** (bankorea.com). The body of the emails was disguised as a message from the Central Bank, saying that the recipient's online-banking service had been suspended due to attempts to gain unauthorised access to the person's account..

Major events: targeted attacks on banks

NotCobalt

On **13 February**, **Reuters** reported that the **Bank of Valetta**, which accounts for almost half of Malta's banking operations, had been attacked by hackers, who had stolen funds and shifted them overseas. It is notable that three of a total of five documents contained Cobalt metadata in the name of the author. The criminals used the **Squibledoo** technique, which Cobalt had earlier employed with a JS backdoor. The main tool was the **CobaltStrike** framework. The domain names were very similar to what Cobalt had used in their attacks. It looked as if it was Cobalt who was behind the **Bank of Valetta** attack. That, however, was not true. Group-IB believes they were imitators. On 27 February 2019, the criminals launched a new attack using the domain socgen-cert [.] com. They deleted the IP address from the domain a day later and it is now unavailable. On the same day, the criminals registered the domain name finanstilsy.net. At first, it was linked to an IP address that had been used by the real group. The criminals did that intentionally in order to imitate Cobalt and throw researches off the track.

Cobalt

On **27 February**, **Cobalt** sent emails to European banks. Their malware was detected in **Romania** and the **UK**. The same domain had been used in previous attacks. Earlier, on 30 January, Cobalt sent emails to individuals well known in the finance industry. The emails were disguised as a message from an **Interra Credit Union** employee. Group-IB discovered at least 6 different text files, containing login-password pairs and email accounts, which had been used in the attack. The emails contained a PDF attachment (the name of the attachment contained the name of the recipient). Inside the PDF, there was a URL link to interrafcu.com [13.58.155.133] through which the malicious file was downloaded.

Major events: leaks

Pakistani banks' cards

Group-IB discovered new databases with **69,189** Pakistani banks' cards, which had been put up for sale on underground forums. The overall market value of the databases is estimated at **$3.5m**. Group-IB already reported about major leaks of 177,878 payment cards of Pakistani and other international banks in November 2018. The second big sale of Pakistani banks' cards in the past 6 months may point to the activity of advanced and financially motivated hackers. The experts discovered two new databases with tens of thousands of Pakistani banks' cards, which had been put up for sale on **Joker's Stash**, one of the most popular card shops at the end of 2019. 96% of all the data were related to **Meezan Bank Ltd**. Pakistani bank cards are rarely sold on underground card shops. This, and the fact that all the cards were up for sale with PIN codes explains the high price, which was **$50** per card. The usual price for one card on dark web forums ranges from **$10 to 40**. The first set of dumps, titled **PAKISTAN-D + P-01**, was put up for sale on January 24 2019 and included 1,535 cards, 1,457 of which had been issued by Meezan Bank Ltd. The second database was put up for sale on Joker's Stash on 30 January. The **PAKISTAN-D + P-02** set comprised the details of **67,654** Pakistani bank cards, a significantly bigger number. Unlike the first set, the second set was actively advertised by the sellers on all major underground forums, such as Omerta, Crdclub, Enclave, etc. 96% of all the cards in the set were related to Meezan Bank Ltd.

Dream Market

620m accounts stolen from **16** hacked websites (Dubsmash, Armor Games, 500px, Whitepages, ShareThis), have been put up for sale on the popular black market **Dream Market**. While some of the mentioned websites are known to have been hacked (for instance, MyHeritage and MyFitnessPal), some of the leaks have never been reported before. Most of the dumped data were account holder names, email addresses and hashed passwords (in some cases the passwords were hashed with the MD5 algorithm, which simplifies their dehashing by hackers).

Major events: tools and services

Cetan Office Kit	A user named *cetan* made a post on exploit.in, an underground forum, to sell a macro generator called Cetan Office Kit. Its main features are combined obfuscation algorithms and the ability to bypass 26 antiviruses. According to the post, the generator is unique: it does not contain any code snippets from other similar programs and is written in C#. The software was created to generate Office documents with a macro that executes the malicious code.
SpeakUp	**Check Point** experts have discovered a new backdoor called SpeakUp, intended for Linux servers in East Asia and Latin America. SpeakUp uses known vulnerabilities in six different Linux distributions and can also infect Mac systems. The Trojan is distributed through a remote code execution vulnerability. For initial infection, it exploits the newly discovered CVE-2018-20062 vulnerability in **ThinkPHP**. The researchers link the author of SpeakUp with the malware developer **Zettabithf**. The majority of the infected machines are located in China. The sample Check Point analysed on 14 January 2019 was also from China.
Trickbot	The notorious banking Trojan Trickbot is back, say **Trend Micro** experts. The new variant of Trickbot can grab remote application credentials. The virus is distributed via spam emails, which are disguised as tax incentives for **Deloitte**, a financial company. The spam emails contain a Microsoft Excel spreadsheet that supports macros (XLSM) and presumably contains data related to tax incentives. The built-in macro downloads and launches Trickbot on the user's computer.

Major events: vulnerabilities and ransomware

WinRAR

Check Point has reported about vulnerabilities in **WinRAR** (CVE-2018-20250, CVE-2018-20251, CVE-2018-20252 and CVE-2018-20253), which allow criminals to extract archive files to a folder chosen by the creator of the archive rather than the user of the programme. The cause of the problem is the UNACEV2.DLL library which unpacks ACE archives. It has not been updated since 2005. Check Point specialists demonstrated the attack exploiting this vulnerability: the executable file is extracted to the startup folder, where it will be launched each time the system is restarted. There are about **500** million WinRAR users worldwide.

0-day

On 3 March, the user **Shark Jeem** made a series of posts about three 0-day vulnerabilities in **Tor**, **Internet Explorer** and **Qihoo 360 Browser**. According to Shark Jeem, all these vulnerabilities affect the latest versions of the products. Videos of how to exploit these vulnerabilities were also provided.

STOP Ransomware

Experts have noticed that the STOP Ransomware virus installed Azorult, a spy Trojan, to steal account data of crypto wallets. AZORult was first detected in 2016 by Proofpoint. The virus has been part of many mass-spamming campaigns but it was only in July 2018 that the authors released a heavily updated variant of it, which was first used in bulk emails on 18 July. A new variant was introduced in October. It can steal more data, including crypto wallet account data.

Legal cases and arrests

Pony Formgrabber

The Russian police together with experts from Group-IB have arrested a **botnet** administrator in Novokuznetsk, Kemerovo Region. The botnet comprised several thousand infected computers within and outside Russia. The detainee was a mercenary, who offered cybercriminal groups **cybercrime as-a-service**. The detainee deployed, tested and serviced Trojans' admin panels on rented servers. They also stole accounts (logins and passwords of email clients and browsers) to sell them on underground forums. The investigation was launched after a major incident in the spring of 2018, when the Novokuznetsk hacker infected about 1,000 personal computers within and outside Russia. The attacker managed to gain access to their victims' email accounts and correspondence using the **Pony Formgragger** Trojan intended for account theft. The botnet existed for a year between autumn 2017 and August 2018. During that period it stole personal data and accounts from the infected devices: logins, passwords, bank card information, etc. The police believe that the detainee offered their services as an administrator on underground forums and had occasional orders from cybercriminals to set up servers to manage botnets. Their potential affiliation with a particular hacking group and side jobs with other groups is also being considered.

Legal cases and arrests

Vishing

The **Moscow police** with support from Group-IB arrested a group of phone fraudsters who scammed old pensioners (from 30,000 to 300,000 rubles) promising them big compensation for previously purchased medicines, medical devices and dietary supplements. The damage from seven reported fraud incidents is estimated at **10m** rubles, but the police say the number of victims could be much higher. The police tracked the phone fraudsters in late 2018. The group scammed old Russian pensioners, obtaining large sums of money. They used it to buy real estate, cars, collector coins, jewelry and securities. The investigators believe the fraud scheme was conceived and implemented by a 35-year-old Azerbaijani-born resident of Domodedovo, Moscow Region. Apart from the leader, the group included callers who talked to the pensioners over the phone, cashiers who managed the transactions, money mules who took out cash at ATMs, and even a specialist who ensured the phone database of potential victims was up to date and secure. At the moment, a criminal case has been instituted under **part 4 of article 159 of the Russian Criminal Code** (Fraud). 7 people have been arrested. The investigators estimate the damage from the fraud at 10m rubles, but the actual number of victims is believed to be much higher: at least 30 people.

Forecasts and warnings

- Despite Group-IB's warnings after detecting GMO, a new JS Sniffer intended for intercepting user data (bank card numbers, names, addresses, logins and passwords), some of the affected websites have not deleted the sniffer.
- Criminals can inject malware of any kind into the target system using Cetan Office Kit, a new macro generator, which allows them to collect sensitive information about the user and exploit their resources, etc.
- Details of **70,000** Pakistani banks' cards have been put up for sale on the Dark Web. The information can be used by financially motivated cybercriminals to attack bank customers, steal their money, and engage in fraud and blackmail.
- Due to the discovery of new **WinRAR** vulnerabilities, we recommend using the newest version of WinRAR where the vulnerabilities have been eliminated (WinRAR 5.70 Beta 1).

If you wish to receive more detailed information about a specific incident, threat or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com